INFORME DE INCIDENTE: ACCESO NO AUTORIZADO Y ROBO DE DATOS EN SERVIDOR WEB

Caso Práctico Simulado — Analista de Seguridad SOC (Nivel 1)

Pelayo Fernández Ojanguren
Entorno: Logística Global S.A.

Caso práctico

En el turno de mañana, el panel del SIEM de Logística Global S.A. muestra una alerta crítica generada de madrugada. Al extraer los logs aparece esta secuencia de eventos en uno de los servidores web de la empresa:

Evento	Hora	Origen del log	Qué ocurrió
Evento 1	03:15	Alerta de Firewall/IPS	Escaneo de puertos masivo al servidor web desde la IP externa 203.0.113.45
Evento 2	03:20	Log de autenticación	150 intentos de inicio de sesión fallidos en el servicio SSH (puerto 22) para el usuario "Administrador", todos desde la misma IP
Evento 3	03:25	Log de autenticación	1 inicio de sesión exitoso del usuario "Administrador" desde esa misma IP
Evento 4	03:45	Log de red (tráfico)	Transferencia inusual de 5 GB de datos comprimidos desde el servidor web hacia una IP desconocida en el extranjero

A. Vector de Ataque y Detección de Herramientas

1. Tipos de logs

- Los eventos 2 y 3 corresponden a logs de autenticación: 150 intentos fallidos de inicio de sesión por SSH y 1 inicio de sesión exitoso como "Administrador".
- Son esenciales ya que registran el acceso a los recursos del sistema. Identifican quién, cuándo y la dirección IP desde la que intenta autenticarse. Anomalía detectada → 150 intentos fallidos de inicio de sesión.

2. Herramientas de auditoría

- Lo más seguro para este tipo de reconocimiento y escaneo de puertos es que el atacante utilizara la herramienta Nmap. Esta permite descubrir hosts activos, puertos TCP/UDP abiertos y vectores de entrada expuestos.

3. Sniffers

- En caso de que las comunicaciones viajaran en texto plano, sin cifrar, como podría ser el caso de HTTP, la herramienta estándar para interceptar, capturar e inspeccionar estos paquetes sería Wireshark. Esta podría leer datos sensibles como contraseñas o correos.

B. Análisis y Correlación de Eventos

1. Tipo de ataque (03:20 AM – 03:25 AM)

- Se produjo un ataque de fuerza bruta contra el servicio SSH expuesto en el puerto 22. El atacante ejecutó múltiples intentos de contraseñas hasta dar con la credencial válida para el usuario privilegiado "Administrador".

2. Objetivo y Tríada CIA

- El objetivo final del atacante fue la exfiltración de información corporativa crítica: 5 GB de datos comprimidos extraídos hacia una IP externa.
- Esto supone una violación de la Confidencialidad, ya que información restringida y confidencial de la compañía quedó expuesta a un tercero no autorizado.
- Con los logs actuales está confirmado el acceso como Administrador y la salida de los 5 GB. Aún falta por comprobar que datos exactos había en en ellos

C. Medidas de contención y respuesta

1. Terminación de sesiones y aislamiento de la red

- Antes de aislar o limpiar nada, guardar una copia de los logs y del estado del servidor como evidencia, para poder investigar qué ocurrió.
- Eliminar cualquier proceso o sesión activa de SSH asociada a la IP del atacante o al usuario Administrador.
- Aislar temporalmente el servidor web a nivel de red interna para evitar movimientos laterales hacia otros sistemas de la organización.

2. Contraseña del Administrador

- Restablecer de inmediato la contraseña por otra credencial robusta generada aleatoriamente.
- Desactivar el acceso SSH directo al usuario Administrador e implantar autenticación de doble factor.

3. Regla del firewall

- Implantar una regla de denegación explícita en el firewall perimetral y en el cortafuegos local, bloqueando todo el tráfico entrante y saliente de la IP 203.0.113.45.
- Bloquear también la IP de destino a la que se enviaron los 5 GB (Evento 4), para cortar la salida de datos.

D. Conclusión ejecutiva

El incidente evidencia el compromiso de la cuenta Administrador del servidor web corporativo, originado a través de un escaneo de puertos inicial, seguido de un ataque de fuerza bruta a SSH que desencadenó en la sustracción de 5 GB de datos de la empresa Logística Global S.A. En infraestructuras corporativas modernas, el volumen de registros que generan los servidores, cortafuegos y sensores de red es inasumible para una monitorización manual, por eso es indispensable el uso de un sistema SIEM. Este permite centralizar, normalizar y correlacionar automáticamente los patrones anómalos detectados en un orden cronológico. Una gestión proactiva y la configuración de umbrales automáticos de alerta habrían bloqueado la IP de origen al detectar el escaneo de puertos masivo o al superarse el límite de intentos SSH fallidos. Además, la alerta crítica saltó de madrugada pero no se revisó hasta el turno de mañana, cuando los datos ya habían Salido. Las alertas críticas deberían avisar al momento a un técnico de guardia, también por la noche. De haberse aplicado contramedidas reactivas tempranas, como el bloqueo temporal mediante herramientas de prevención de intrusiones, se hubiera neutralizado el vector de ataque antes de que se produjera la exfiltración masiva de datos a las 03:45.